

SKILL PARA CLAUDE CODE

Auditoria de Segurança

O que a IA não checkou por você

Você pediu um sistema. Ela entregou um sistema que funciona. Funcionar e estar seguro são duas coisas diferentes, e ninguém verificou a segunda.

Numa auditoria de 1.400+ aplicações construídas com IA: 65% tinham falha de segurança, 58% pelo menos uma crítica, e 88% dos apps com Supabase estavam com Row Level Security inteiramente desabilitado.

Segurança aberta é FALHA, não dívida: está errada desde o primeiro dia e custa o mesmo para arrumar hoje ou daqui a um ano.

Palavra-chave desta skill: **BLINDAR**

Crítico — antes de qualquer pessoa usar

Row Level Security desligado	qualquer visitante abre o DevTools e lê sua tabela inteira
Chave de API no frontend	a chave está no bundle; qualquer um extrai e usa no seu crédito
Segredo commitado no repositório	quem clonar tem suas credenciais, mesmo que você apague o arquivo hoje
Rota de API sem autenticação	chamam a rota direto, sem passar pela sua interface

Alto — antes de produção

CORS liberado para qualquer origem	qualquer site chama sua API com a sessão do seu usuário
Sem rate limit em rota cara	um script roda sua fatura até o teto em minutos
Webhook sem verificação de assinatura	qualquer um forja um evento de pagamento aprovado
Erro devolvendo stack trace	você entrega estrutura interna e às vezes credencial

Médio — corrigir em breve

Input indo direto para query	injeção de SQL ou de operador
Upload sem validar tipo e tamanho	arquivo malicioso ou disco cheio
Headers de segurança ausentes	clickjacking e downgrade de conexão
Dependência com CVE conhecido	falha pública, exploração conhecida

Como usar

1. Baixe o arquivo da skill no link abaixo.
2. Mande o arquivo para o seu Claude Code e diga: *"instala essa skill pra mim"*. Ele resolve o resto.
3. Dentro da pasta do seu projeto, peça: *"auditoria de segurança nesse projeto"*.
4. Leia o laudo. Cada ponto aberto tem arquivo, linha e o que fazer.

<https://redpro.com.br/redreply/skills/auditoria-seguranca.md>

